Handoff 37: Pin CI actions to commits (master run WE7, SEC-08)

Date: 2026-11-02 (America/Toronto)
Written by: Claude Code (implementer), in a separate git worktree
For: the human maintainer, and ChatGPT or Claude chat (reviewer) without repository access
Status: **in_review**: one pull request (#42), not merged. Changes the workflow file and adds a test. No app code, and nothing a learner sees.

> **How to use this file:** the pull request diff is the source of truth (`build.md` section 14).

Starter prompt for the chat assistant

```
You are reviewing a small supply-chain change: Python Academy's GitHub Actions
workflow now pins each action to a full commit SHA. Check that each SHA is the
one its version tag points at, and that the test keeps them pinned.
```

Run plan details

Field	Value
Stage	WE7, one part (SEC-08). SEC-05, SEC-06 and ENG-11 are not in this PR
Base	`main`, at `ac167e3`. No other PR needs to merge first
Part 2 boxes relied on	**None**
Taken out of order	UI-02 to UI-04 come first in WE5, but I did not start them (section 7)

1. Step 0

`git fetch --all`, `gh pr list --state all`: #39, #40 and #41 open. Worktree `../python-academy-sec08`; the main folder was not switched.

2. Handoff record (build.md template)

Field	Value
Task	SEC-08: pin CI actions to commit SHAs
Human goal	A moved or hijacked version tag cannot change what runs in CI
Non-goals	"Routine dependency updates", the second half of SEC-08 (question 1); the `postgres:16` test image; any GitHub setting
Data and compatibility	None
Deployment status	Not requested. **The workflow file is in the repository; no GitHub setting was changed**

Files changed

`.github/workflows/ci.yml`, `backend/tests/test_ci_pins.py` (new, 3 tests), `docs/run-log.md`, this handoff and its PDF.

3. What changed

Action	Version	Pinned commit (read from GitHub's API; the tag points straight at it)
`actions/checkout`	v4	`11d5960a326750d5838078e36cf38b85af677262`
`actions/setup-python`	v5	`a26af69be951a213d495a4c3e4e4022e16d87065`
`actions/setup-node`	v4	`49933ea5288caeca8642d1e84afbd3f7d6820020`

The same versions as before, so CI should behave the same. The version stays beside each pin as a comment, so a person can read it. The workflow's `permissions: contents: read` is unchanged.

4. Decisions and why

Decision	Options considered	Reason	Who decided
Keep the same major versions	Upgrade while pinning	One change at a time	Implementer
A test that keeps pins in place	Rely on review	A later edit could quietly bring back a tag	Implementer
No Dependabot config	Add one	It would open PRs of its own, which is yours to decide	Implementer (**question 1**)

5. Bugs found and how they were fixed

None.

6. How it was tested

Check	Result
`cd backend && pytest -q` on SQLite	All pass, with 3 new
The workflow itself	**Only CI can prove this: this PR's own run uses the pinned actions.** Check it's green
Playwright	Not run locally, as no frontend code changed; CI runs it

Deliberate break (each undone)	Result
B1. `checkout` back to a tag	The pin test fails
B2. `setup-node` to a short commit	The pin test fails
B3. The version comment removed	The pin test fails

What this does not prove: a pinned action can still fetch other things as it runs, and pins don't update themselves, so security fixes in these actions now need a person or a tool.

7. Why UI-02 to UI-04 were not started

The queue puts these first, and they have no gate. I stopped short of them because they raise questions that are yours:

- **UI-02, "Not now":** Python is the only released course. Dismissing it would leave a learner with nothing recommended.
- **All three add personal data,** in a new table or new events, that `retention.md` doesn't cover yet.
- **The migration number:** S04 is planned as `0009`, and building these first would take it.
- **The backlog rates all three "Later".**

8. Live checks for you

Check this PR's CI is green. There is nothing to check on the site.

9. Questions for you

1. **Automatic updates for pinned actions?** *Recommended, not yet confirmed: add Dependabot for GitHub Actions only, monthly. It's free, and it opens PRs for you to review.*

2. **UI-02 to UI-04: build them now, or wait for a second course?** *Recommended, not yet confirmed: wait.*

10. For the docs sync

Where	What
Backlog SEC-08	proposed → in_review for the pins (#42, handoff 37); dependency updates not done
Stage table	"37. SEC-08 | Pin CI actions | in_review (#42, handoff 37)"

11. Next concrete action

Review and merge once CI is green.

12. Removing the worktree safely

From the **main** folder, after this PR is merged:

```
cd /Users/DEV/Projects/python-academy
git -C ../python-academy-sec08 status --short   # expect nothing
git worktree remove ../python-academy-sec08     # deletes only that folder; refuses if
anything is uncommitted
git worktree prune
git branch -d sec/pin-ci-actions                # refuses if the branch is not merged
```

Don't delete the folder in the Finder or with `rm -rf`; Git would keep a stale record of it (`git worktree prune` fixes that).